TP2 : Analyse de trafic TLS avec Wireshark

Dr Malaw NDIAYE

2025

1 Introduction

Ce TP vous permettra de comprendre le fonctionnement du protocole TLS (Transport Layer Security) en analysant des captures réseau avec Wireshark. Vous apprendrez à identifier les différentes phases d'une connexion TLS, à analyser le processus de handshake, et à décrypter du trafic TLS lorsque vous disposez des clés appropriées.

Objectifs du TP

- Comprendre le fonctionnement du protocole TLS/SSL
- Identifier les différentes phases du handshake TLS
- Analyser les certificats numériques
- Décrypter du trafic TLS avec les clés de session
- Détecter des anomalies de sécurité potentielles

Prérequis

- Connaissances de base en réseaux TCP/IP
- Notions de cryptographie (chiffrement symétrique/asymétrique)
- Wireshark installé sur votre machine
- OpenSSL installé (optionnel)
- Navigateur web (Firefox ou Chrome)

2 Partie 1 : Capture et analyse basique du trafic TLS

2.1 Préparation de l'environnement

2.1.1 Configuration de Wireshark

1. Lancez Wireshark avec les privilèges appropriés
2. Sélectionnez l'interface réseau active (généralement WiFi ou Ethernet)
3. Appliquez le filtre de capture : `tcp port 443`

Attention

Sur certains systèmes, vous devrez lancer Wireshark en tant qu'administrateur pour capturer le trafic réseau.

2.1.2 Génération de trafic TLS

1. Démarrez la capture dans Wireshark
2. Ouvrez votre navigateur web
3. Visitez le site : `https://www.example.com`
4. Arrêtez la capture après le chargement complet de la page

2.2 Analyse du handshake TLS

2.2.1 Identification des paquets

Dans Wireshark, appliquez le filtre d'affichage :

```
ssl.handshake
```

ou pour les versions plus récentes :

```
tls.handshake
```

2.2.2 Questions d'analyse

Q1. Combien de paquets composent le handshake TLS complet ?

Q2. Identifiez et listez les différents messages du handshake dans l'ordre :

- Client Hello
- Server Hello
- Certificate
- Server Key Exchange (si présent)
- Server Hello Done
- Client Key Exchange
- Change Cipher Spec
- Finished

Q3. Quelle version de TLS est négociée ? (TLS 1.0, 1.1, 1.2, 1.3)

2.3 Analyse détaillée du Client Hello

Sélectionnez le paquet **Client Hello** et analysez les champs suivants :

Q4. Quelle est la version maximale de TLS supportée par le client ?

Q5. Listez les cipher suites proposées par le client (au moins 5)

Q6. Quelles sont les courbes elliptiques supportées ? (extention Key Share (TLS 1.3) - x25519)

Q7. Le client supporte-t-il l'extension SNI (Server Name Indication) ? Si oui, quel nom de domaine est indiqué ?

Q8. Identifiez les autres extensions proposées par le client

2.4 Analyse détaillée du Server Hello

Sélectionnez le paquet **Server Hello** :

Q8. Quelle cipher suite a été sélectionnée par le serveur ?

Q9. Décomposez cette cipher suite (algorithme d'échange de clés, chiffrement, MAC)

Q10. Le serveur a-t-il activé la compression ?

Q11. Quelle est la longueur du Session ID ?

3 Partie 2 : Analyse des certificats

3.1 Extraction du certificat serveur

Dans le paquet **Certificate**, développez l'arborescence pour visualiser le certificat.

Q12. Qui est l'émetteur (Issuer) du certificat ?

Q13. Qui est le sujet (Subject) du certificat ?

Q14. Quelle est la période de validité du certificat ?

Q15. Quel algorithme de signature est utilisé ?

Q16. Quelle est la taille de la clé publique ?

Q17. Le certificat contient-il l'extension Subject Alternative Name (SAN) ? Si oui, listez les domaines couverts.

3.2 Vérification de la chaîne de certification

Q18. Combien de certificats sont envoyés par le serveur ?

Q19. Identifiez la hiérarchie : certificat serveur → certificat intermédiaire → certificat racine

Q20. Le certificat racine est-il inclus dans la chaîne ? Pourquoi ?

3.3 Exportation du certificat

Pour exporter le certificat depuis Wireshark :

1. Clic droit sur le champ Certificate
2. Export Packet Bytes
3. Sauvegardez avec l'extension .der

Vous pouvez ensuite l'examiner avec OpenSSL :

```
openssl x509 -in certificate.der -inform DER -text -noout
```

4 Partie 3 : Décryptage du trafic TLS

4.1 Configuration pour capturer les clés de session

4.1.1 Sur Firefox

1. Fermez complètement Firefox
2. Créez une variable d'environnement :
   Windows (PowerShell) :

```
$env:SSLKEYLOGFILE="C:\temp\sslkeys.log"
```

   Linux/Mac :

```
export SSLKEYLOGFILE=~/sslkeys.log
```

3. Relancez Firefox depuis ce terminal

4.1.2 Configuration de Wireshark

1. Menu : Edit → Preferences
2. Protocols → TLS (ou SSL)
3. Dans "(Pre)-Master-Secret log filename", indiquez le chemin du fichier sslkeys.log
4. Cliquez sur OK

4.2 Capture et décryptage

1. Démarrez une nouvelle capture dans Wireshark
2. Visitez `https://www.example.com` avec Firefox
3. Arrêtez la capture
4. Appliquez le filtre : `http`

Q21. Pouvez-vous maintenant voir les requêtes HTTP en clair ?

Q22. Identifiez la requête GET et analysez les en-têtes HTTP

Q23. Quel est le User-Agent utilisé ?

Q24. Identifiez la réponse HTTP. Quel est le code de statut ?

5 Partie 4 : Analyse de sécurité

5.1 Vérification des bonnes pratiques

En vous basant sur votre capture, répondez aux questions suivantes :

Q25. La connexion utilise-t-elle TLS 1.2 ou supérieur ?

Q26. Les cipher suites utilisées sont-elles considérées comme sécurisées ?

Q27. Le Perfect Forward Secrecy (PFS) est-il assuré ?

Q28. Le certificat utilise-t-il au minimum une clé RSA de 2048 bits ou une clé ECDSA ?

5.2 Détection de problèmes potentiels

Q29. Y a-t-il des tentatives de connexion en TLS 1.0 ou 1.1 ? (protocoles obsolètes)
Q30. Des cipher suites faibles sont-elles proposées ? (ex : RC4, DES, export ciphers)
Q31. Le certificat est-il auto-signé ou émis par une CA reconnue ?

6 Partie 5 : Analyse d'une attaque (Optionnel)

6.1 Simulation d'une attaque Man-in-the-Middle

Attention

Cette section est à réaliser UNIQUEMENT dans un environnement de test contrôlé. Ne tentez jamais d'attaquer des systèmes sans autorisation explicite.

6.1.1 Mise en place avec mitmproxy (optionnel)

Si le temps le permet et avec l'accord de l'enseignant, vous pouvez installer mitmproxy pour observer une interception TLS :

```
# Installation
pip install mitmproxy

# Lancement
mitmproxy -p 8080
```

Q32. Que se passe-t-il au niveau des certificats lors d'une interception MITM ?
Q33. Quels sont les indicateurs visibles dans le navigateur ?
Q34. Comment un utilisateur peut-il détecter une telle attaque ?

7 Partie 6 : Questions de synthèse

Q35. Expliquez la différence entre TLS 1.2 et TLS 1.3 au niveau du handshake
Q36. Pourquoi le Perfect Forward Secrecy est-il important ?
Q37. Quel est le rôle de l'extension ALPN (Application-Layer Protocol Negotiation) ?
Q38. Expliquez le principe de la reprise de session TLS (Session Resumption)
Q39. Quels sont les avantages du protocole HSTS (HTTP Strict Transport Security) ?

8 Ressources complémentaires

- RFC 8446 : The Transport Layer Security (TLS) Protocol Version 1.3
- RFC 5246 : The Transport Layer Security (TLS) Protocol Version 1.2
- Wiki Wireshark TLS : `https://wiki.wireshark.org/TLS`
- Mozilla SSL Configuration Generator : `https://ssl-config.mozilla.org/`
- Qualys SSL Labs : `https://www.ssllabs.com/ssltest/`

Bon courage !